

Lab 11 - Bypass de MFA mediante AiTM



Prof. Dr. Luiz F. Freitas-Gutierrez

luiz.gutierrez@ufsm.br

linkedin.com/in/lffreitas-gutierrez



Lattes

ORCID

SciProfiles

Scopus

ResearcherID

substationworm

LFreitasGutierrez

Resumen del problema

Hosts en contenedores

- user-browser (estación víctima): sistema cliente legítimo usado por el operador para acceder a la interfaz web industrial. Es el objetivo del robo de credenciales y del compromiso de sesión.
- phishing-proxy (proxy AiTM): servicio malicioso que retransmite de forma transparente las comunicaciones entre la estación víctima y el servidor HMI legítimo mientras captura credenciales y cookies de sesión.
- legit-hmi (servidor HMI autorizado): sistema HMI legítimo que proporciona control y supervisión operativa dentro del entorno industrial.
- attacker (atacante): actor malicioso que despliega y gestiona la infraestructura de phishing para realizar robo de credenciales, secuestro de sesión y persistencia de acceso.

Tareas

- **1** Accede al contenedor víctima (user-browser) y abre el navegador web en modo texto con: `elinks http://phishing.test`. El usuario cree que está accediendo al HMI legítimo, pero en realidad se conecta a un dominio falso y malicioso diseñado para parecerse al auténtico.
- **2** Auténticate con las credenciales siguientes: operator (usuario), otlab123 (contraseña), 000111 (código MFA). Tras la autenticación, explora la interfaz web del HMI. No cierres sesión todavía.
- **3** En otra terminal, accede al contenedor atacante y ejecuta: `tail -f /loot/cookies.log`. El proxy de phishing interceptará y registrará la cookie de sesión de la víctima, permitiendo el bypass de MFA y el secuestro de sesión.
- **4** Asigna la cookie capturada a una variable llamada COOKIE en el sistema atacante. Después reutiliza la cookie para acceder a la aplicación a través del proxy de phishing: `curl -H "Cookie: ihhmsession=$COOKIE" -H "Host: phishing.test" http://172.30.0.20/home -L`. Se espera acceso exitoso sin confirmación MFA.
- **5** En el sistema atacante, prueba el acceso directo al servidor HMI autorizado usando la cookie robada: `curl -H "Cookie: ihhmsession=$COOKIE" http://legit-hhm:8000/home` o `curl -H "Cookie: ihhmsession=$COOKIE" -H "Host: legit.test" http://172.30.10.40:8000/home`. Este paso simula el uso de una sesión válida directamente contra la infraestructura legítima.

- **6** Realiza un cierre de sesión global haciendo clic en Log out en la sesión de user-browser. Después, intenta reutilizar de nuevo la cookie desde el sistema atacante: `curl -i -H "Cookie: ihhmsession=$COOKIE" -H "Host: phishing.test" http://172.30.0.20/home`. La solicitud debe redirigirse a la página de inicio de sesión, indicando que la sesión ya no es válida.

Herramientas

- Las siguientes herramientas están disponibles para completar OTLab 11: `curl`, `elinks` y `tail`.

Nomenclatura

- AiTM: adversary-in-the-middle.
- HMI: interfaz hombre-máquina.
- ICS: sistema de control industrial.
- MFA: autenticación multifactor.
- OT: tecnología operativa.
- SaaS: software como servicio.
- VPN: red privada virtual.